ValenFind CTF - Sızma Testi ve Zafiyet Analiz Raporu

Hazırlayan: Emircan **Tarih:** 5 Mart 2026 **Hedef Sistem:** ValenFind (IP: 10.113.161.240)

1. Yönetici Özeti

Bu rapor, ValenFind adlı hedef sistem üzerinde gerçekleştirilen sızma testi adımlarını ve tespit edilen güvenlik zafiyetlerini içermektedir. Yapılan testler sonucunda, web uygulamasında bulunan kritik seviyeli bir Yerel Dosya Dahil Etme (Local File Inclusion - LFI) zafiyeti tespit edilmiştir. Bu zafiyet kullanılarak uygulamanın kaynak kodu okunmuş ve kod içerisine gömülü yönetici API anahtarı sızdırılmıştır. Elde edilen bu anahtar ile tüm kullanıcı veritabanı yetkisiz bir şekilde ele geçirilmiştir.

2. Bilgi Toplama (Reconnaissance)

Hedef sisteme yönelik gerçekleştirilen Nmap taraması sonucunda aşağıdaki portların açık olduğu tespit edilmiştir:

- **Port 22 (SSH):** OpenSSH 9.6p1
- **Port 5000 (HTTP):** Werkzeug httpd 3.0.1 (Python 3.12.3)

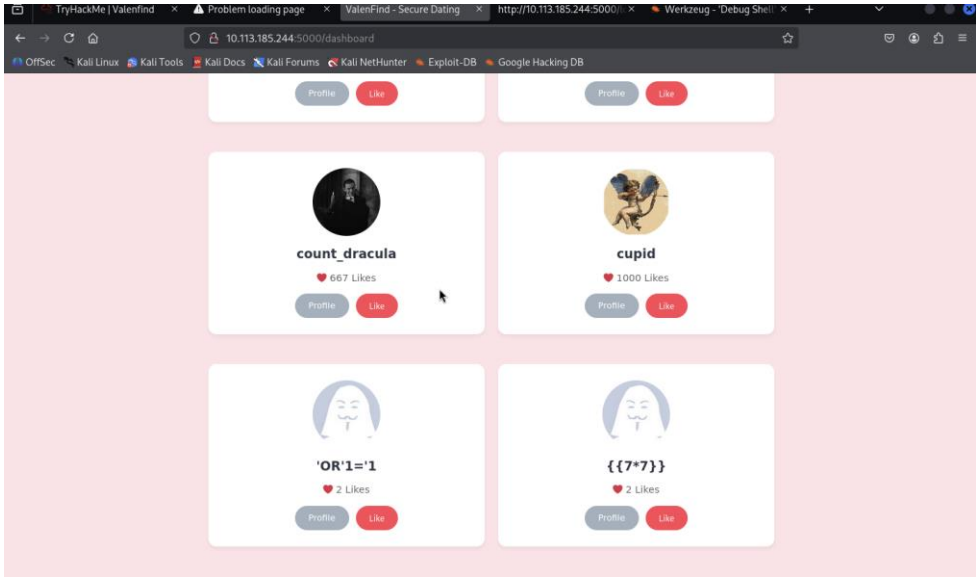
Sistemin ana giriş noktası olarak Port 5000 üzerinde çalışan Flask tabanlı ValenFind web uygulaması belirlenmiş ve analizler bu yönde derinleştirilmiştir.

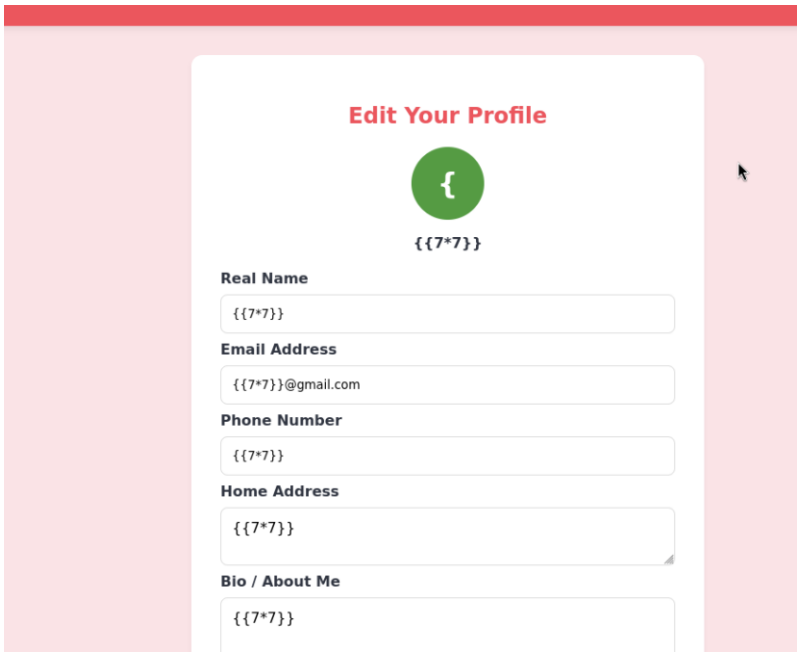
```
┌──(root㉿kali)-[/home/emircan]
└─# nmap -Pn -sS -sV -O 10.113.185.244
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-05 19:19 +03
Nmap scan report for 10.113.185.244
Host is up (0.067s latency).
Not shown: 998 closed tcp ports (reset)
PORT     STATE SERVICE VERSION
22/tcp   open  ssh     OpenSSH 9.6p1 Ubuntu 3ubuntu13.14 (Ubuntu Linux; protocol 2.0)
5000/tcp open  http    Werkzeug httpd 3.0.1 (Python 3.12.3)
No exact OS matches for host (If you know what OS is running on it, see https://nmap.org/submit/ ).
TCP/IP fingerprint:
OS:SCAN(V=7.95%E=4%D=3/5%OT=22%CT=1%CU=31061%PV=Y%DS=3%DC=I%G=Y%TM=69A9AD1D
OS:%P=aarch64-unknown-linux-gnu)SEQ(SP=100%GCD=1%ISR=103%TI=Z%CI=Z%II=I%TS=
OS:A)SEQ(SP=101%GCD=1%ISR=10A%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=105%GCD=1%ISR=107%
OS:TI=Z%CI=Z%TS=A)SEQ(SP=106%GCD=1%ISR=109%TI=Z%CI=Z%II=I%TS=A)SEQ(SP=106%G
OS:CD=1%ISR=10D%TI=Z%CI=Z%II=I%TS=A)OPS(O1=M4E8ST11NW7%O2=M4E8ST11NW7%O3=M4
OS:E8NNT11NW7%O4=M4E8ST11NW7%O5=M4E8ST11NW7%O6=M4E8ST11)WIN(W1=F4B3%W2=F4B3
OS:%W3=F4B3%W4=F4B3%W5=F4B3%W6=F4B3)ECN(R=Y%DF=Y%T=40%W=F507%O=M4E8NNSNW7%C
OS:C=Y%Q=)T1(R=Y%DF=Y%T=40%S=O%A=S+%F=AS%RD=0%Q=)T2(R=N)T3(R=N)T4(R=Y%DF=Y%
OS:T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T5(R=Y%DF=Y%T=40%W=0%S=Z%A=S+%F=AR%O=%RD
OS:=0%Q=)T6(R=Y%DF=Y%T=40%W=0%S=A%A=Z%F=R%O=%RD=0%Q=)T7(R=Y%DF=Y%T=40%W=0%S
OS:=Z%A=S+%F=AR%O=%RD=0%Q=)U1(R=Y%DF=N%T=40%IPL=164%UN=0%RIPL=G%RID=G%RIPCK
OS:=G%RUCK=G%RUD=G)IE(R=Y%DFI=N%T=40%CD=S)

Network Distance: 3 hops
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 19.78 seconds
```

3. Zafiyet Analizi ve Sömürü Adımları

3.1. Girdi Kontrolü ve Şablon Enjeksiyonu Testleri

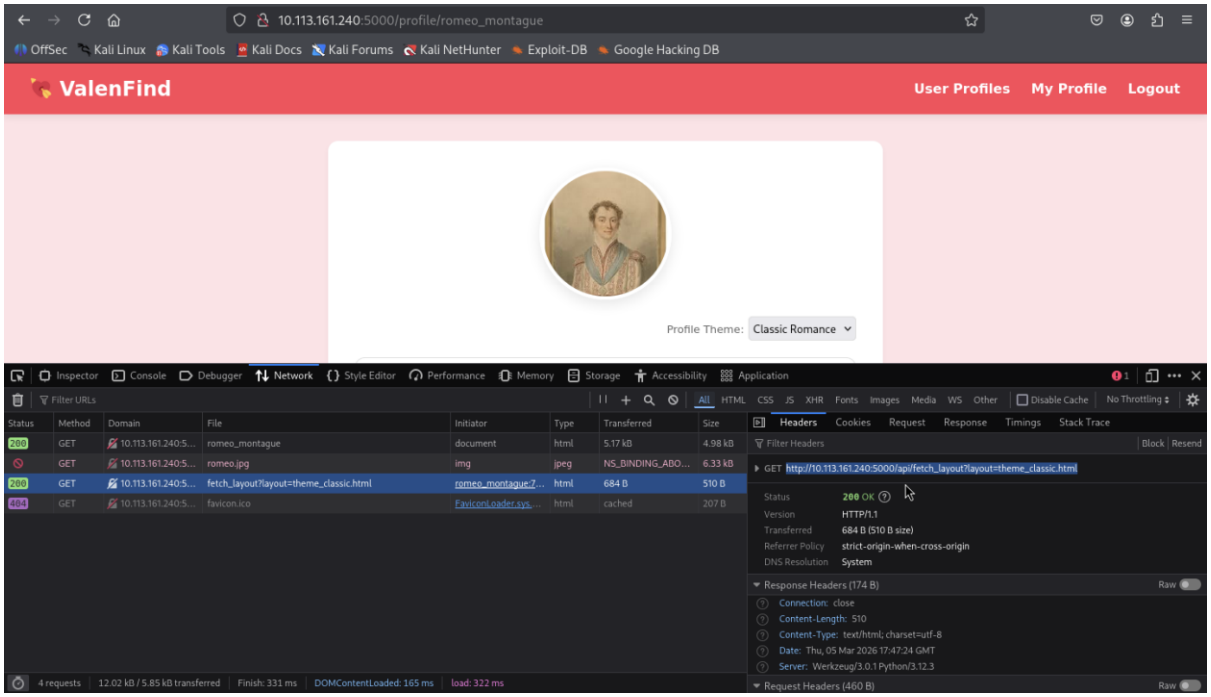
Uygulamanın kayıt (register) ve giriş (login) formları ile profil düzenleme alanları incelenmiştir. Form alanlarına yönelik SQL Injection (SQLi) ve Server-Side Template Injection (SSTI) payload'ları (örn: {{7*7}}, ' OR 1=1 --) gönderilerek testler gerçekleştirilmiştir. Fakat bir sonuca ulaşılamamıştır.



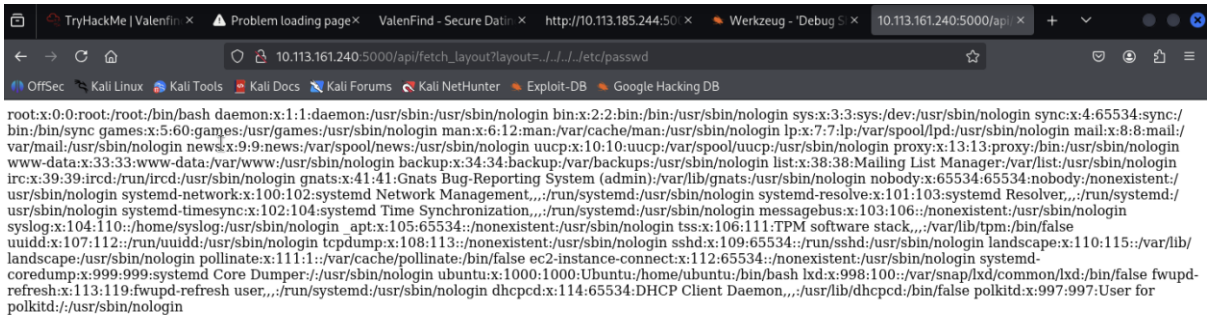


3.2. Yerel Dosya Okuma (LFI) Zafiyetinin Tespiti

Kullanıcı profil sayfasında bulunan "Profile Theme" (Tema Seçimi) mekanizması incelendiğinde, tema değişikliği sırasında sunucuya /api/fetch_layout?layout=theme_classic.html şeklinde bir GET isteği iletildiği görülmüştür.



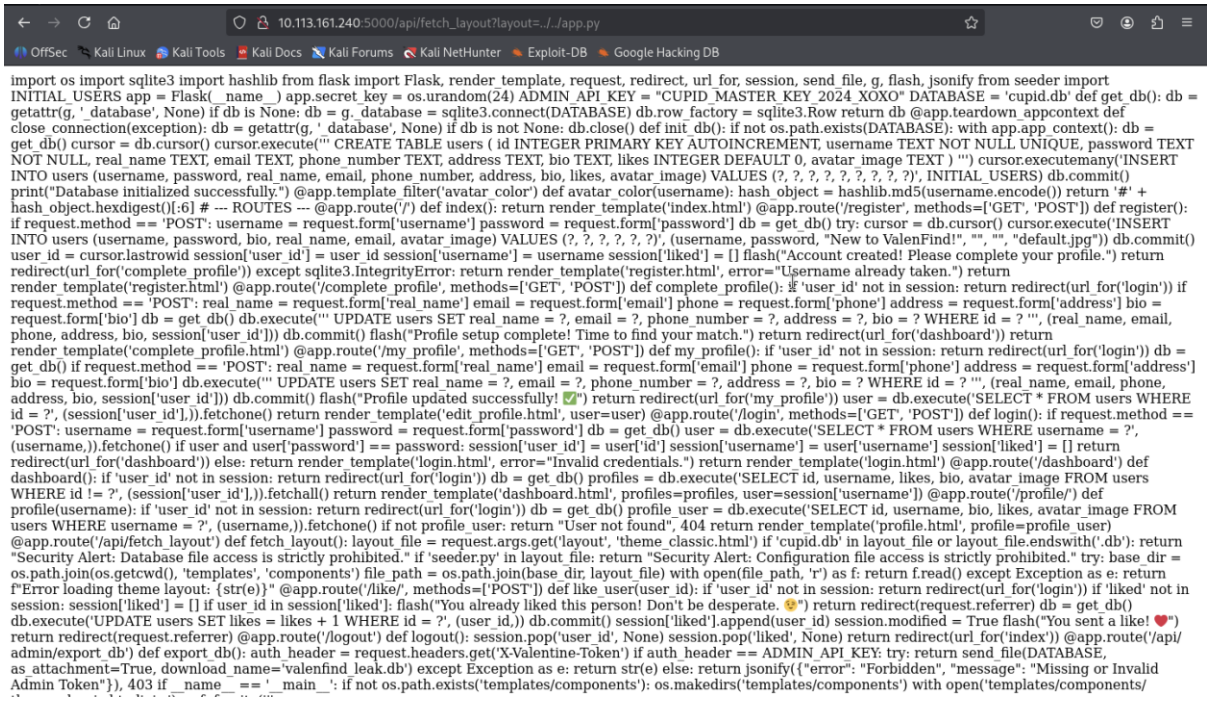
layout parametresinin aldığı değer manipüle edilerek ../../../../etc/passwd payload'ı gönderilmiş ve sunucunun yerel dizinlerindeki dosyaları yetkisiz bir şekilde dışarıya yansıttığı tespit edilmiştir.



3.3. Kaynak Kod İfşası

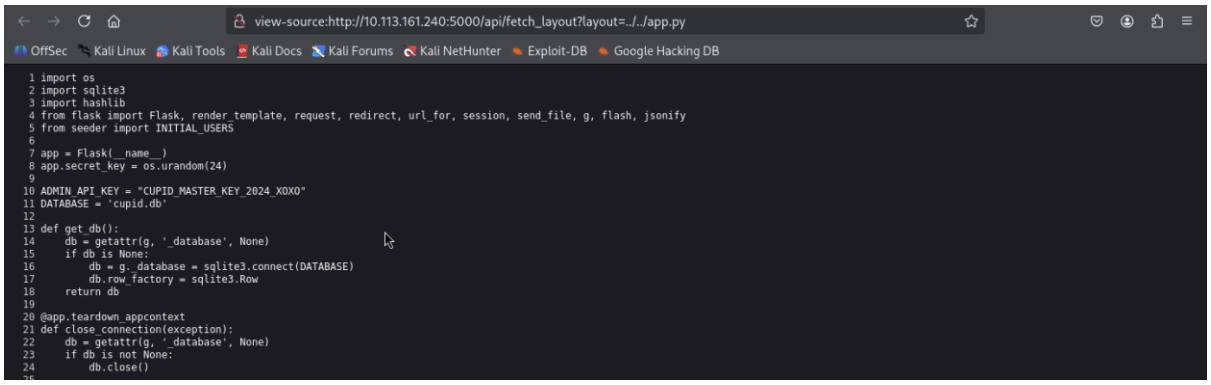
LFI zafiyeti kullanılarak uygulamanın kök dizininde bulunan app.py dosyası okunmuştur (/api/fetch_layout?layout=../../app.py). Bu işlem sonucunda uygulamanın tüm Python

kaynak kodlarına erişim sağlanmıştır.



3.4. API Anahtarı Sızıntısı ve Veritabanının Ele Geçirilmesi

Elde edilen app.py kaynak kodu incelendiğinde, geliştirici tarafından kod içerisine statik olarak gömülmüş bir API anahtarı bulunmuştur: ADMIN_API_KEY = "CUPID_MASTER_KEY_2024_XOXO"



Aynı kod dosyasında, sadece bu anahtarı doğrulayan gizli bir /api/admin/export_db uç noktası (endpoint) keşfedilmiştir. Bulunan API anahtarı, HTTP istek başlıklarına (headers) X-Valentine-Token olarak eklenerek bu uç noktaya bir istek atılmış ve uygulamanın SQLite veritabanı (cupid.db) tamamen indirilerek sistem başarıyla ele geçirilmiştir.

4. Çözüm Önerileri ve İyileştirmeler

Hedef sistemin güvenliğinin sağlanması için aşağıdaki adımların atılması tavsiye edilmektedir:

1. **LFI Zafiyetinin Giderilmesi:** fetch_layout fonksiyonunda kullanıcıdan alınan girdi doğrudan dosya yolu olarak kullanılmamalıdır. Dizin atlatma (path traversal) karakterleri (../) sıkı bir şekilde filtrelenmeli veya sadece izin verilen belirli dosya adlarının (whitelist) kullanımına onay verilmelidir.
2. **Hassas Verilerin Kod İçerisinde Tutulmaması:** ADMIN_API_KEY ve benzeri gizli anahtarlar asla kaynak kod içerisine gömülmemelidir.
3. **API Uç Noktası Güvenliği:** Veritabanı dışa aktarma gibi kritik işlemler yapan uç noktalar dış ağa tamamen kapalı olmalı veya yalnızca yerel ağdan erişilebilir olacak şekilde yapılandırılmalıdır.